

**THREAT ADVISORY****VULNERABILITY
REPORT**

New Zoom vulnerabilities can compromise user devices with a single message

Date of Publication

30 May 2022

Admiralty code

A1

TA Number

TA2022108

Summary

Zoom has addressed four security flaws that, one of them if exploited, can compromise a user via chat by sending specially crafted Extensible Messaging and Presence Protocol (XMPP) messages and executing malicious code.

CVEs

CVE	NAME	PATCH
CVE-2022-22784	Improper XML Parsing vulnerability	
CVE-2022-22785	Improperly constrained session cookies vulnerability	
CVE-2022-22786	Update package downgrade vulnerability	
CVE-2022-22787	Insufficient hostname validation during server switch vulnerability	

Potential MITRE ATT&CK TTPs

TA0042 Resource Development	TA0001 Initial Access	TA0004 Privilege Escalation	TA0011 Command and Control
T1588 Obtain Capabilities	T1588.006 Obtain Capabilities: Vulnerabilities	T1190 Exploit Public-Facing Application	T1068 Exploitation for Privilege Escalation
T1105 Ingress Tool Transfer			

Technical Details

#1

The **first** vulnerability, **CVE-2022-22784**, allows an attacker to counterfeit **XMPP** messages from the server. The **second** vulnerability, **CVE-2022-22785** could allow an attacker to send an unsuspecting users Zoom-scoped session **cookies** to a non-Zoom domain. The **third** vulnerability, **CVE-2022-22786**, could be exploited to trick a user into downgrading their Zoom client to a **less secure** version. The **fourth** vulnerability, **CVE-2022-22787**, could be exploited by a malicious **attacker** to trick an unsuspecting user's client into connecting to a malicious **server** when attempting to access **Zoom** services.

#2

The **Telecommunications and Digital Regulatory Authority (TRDA)** of **United Arab Emirates (UAE)** and the threat research team at **Hive Pro** advises users to **upgrade** to **version 5.10.0** to avoid exploitation.



Vulnerability Details

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-22784	Zoom Client for Meetings before version 5.10.0	cpe:2.3:a:zoom:meetings:*:*:*:*:*:*	CWE-91
CVE-2022-22785			CWE-565
CVE-2022-22787			CWE-295
CVE-2022-22786	All Zoom Client for Meetings and Zoom Rooms for Conference Room for Windows before version 5.10.0	cpe:2.3:a:zoom:meetings:*:*:*:*:*:windows:*:* cpe:2.3:a:zoom:rooms:*:*:*:*:*:windows:*:*	CWE-494



Patch Links

<https://zoom.us/download>



References

<https://explore.zoom.us/en/trust/security/security-bulletin/>

https://twitter.com/tdrauae/status/1530151861080276992?ref_src=twsrc%5Egoogle%7Ctwcamp%5Eserp%7Ctwgr%5Etweet



What Next?

Book a free demo with **HivePro Uni5** to check your exposure to this advisory. HivePro Uni5 is a Threat Exposure Management Solution that proactively reduces an organization's attack surface before it gets exploited.



At Hive Pro we take a long hard look at your vulnerabilities so you can bolster your defenses and fine-tune your offensive cybersecurity tactics.

REPORT GENERATED ON

30 May 2022 • 2:20 PM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com